BITÁCORA DE INTELIGENCIA ARTIFICIAL: REGISTRO DE CONSULTAS, VALIDACIÓN CRIPTOGRÁFICA Y ENDURECIMIENTO DE ACCESO REMOTO SEGURO CON OPENSSH Y FAIL2BAN

Actividad 3: Acceso Remoto Seguro (Laboratorios 10 y 11)

Asignatura: Tecnología Web I (SIS-0150)

Institución: Universidad Privada Domingo Savio (UPDS) — Facultad de Ciencias y Tecnología

---

Autores:

1. **Ketfer Gianella Salazar** (Responsable Técnico)
2. **Charles Yourdan Conde Ugarteche**
3. **Brian Alejandro Calás Despaigne**
4. **Marco Aurelio Barriga**
5. **Adaniel Balderrama Orellana**

Docente Evaluador:

M.Sc. Ing. Jimmy Nataniel Requena Llorentty

Fecha:

25 de Octubre de 2026

Repositorio Oficial de Código (GitHub):

https://github.com/Grupo-Kali-Linuxxxx/Acceso-remoto-seguro

---

1. Declaración de Uso Ético y Metodología de IA

En estricta observancia del código de ética académica de la Universidad Privada Domingo Savio y los lineamientos de evaluación de la asignatura Tecnología Web I, el uso de herramientas de Inteligencia Artificial Generativa se rigió bajo los siguientes principios inviolables:

1. **Privacidad de Credenciales y Secretos Criptográficos:** Jamás se suministraron a la IA claves privadas (`id_ed25519`, `comunicacion_ed25519`), certificados, contraseñas reales ni cadenas de conexión con credenciales institucionales. Las claves privadas permanecieron custodiadas exclusivamente en los clientes autorizados.
2. **Rol de Asistencia Técnica y Conceptual:** La IA fue consultada para:

- Explicación de mecánicas criptográficas avanzadas (curva Edwards25519, KEX híbrido post-cuántico Streamlined NTRU Prime).
- Interpretación de directivas y precedencia sintáctica en OpenSSH 9.6 (`sshd_config.d`, regla de primera aparición gana).
- Depuración de errores en jaulas chroot (`bad ownership or modes for chroot directory`).
- Mapeo de unidades de servicio en Ubuntu 24.04 (`ssh.service` vs `sshd.service` y backend `systemd` para Fail2ban).

3. **Verificación Empírica Obligatoria:** Ninguna respuesta de la IA fue implementada a ciegas. Cada configuración fue sometida a pruebas previas de sintaxis (`sshd -t`), validada en entornos controlados de Docker y certificada mediante los scripts de auditoría oficial de la cátedra (`verificar_lab10.sh` y `verificar_lab11.sh`).

---

2. Registro Cronológico de Interacción con la IA

Sesión 1: Análisis de Tráfico de Red en Wireshark y Vulnerabilidad de TELNET

- **Prompt enviado a la IA:**

> *"¿Cómo reconstruyo un flujo TCP en Wireshark a partir de un archivo pcap para demostrar que TELNET transmite en texto claro, y qué campos específicos revelan la contraseña frente a una captura de SSH?"*

- **Respuesta y Síntesis de la IA:**

La IA explicó el mecanismo de *Follow TCP Stream* (Seguir flujo TCP), indicando que TELNET opera sobre la capa de aplicación sin capa TLS/SSL intermedia, transmitiendo cada paquete TCP con la carga útil (*payload*) en caracteres ASCII legibles. En contraste, en una captura de SSH, tras el intercambio inicial de cadenas de versión (`SSH-2.0-OpenSSH_9.6p1`), el procedimiento Diffie-Hellman establece una clave de sesión simétrica que cifra todos los paquetes posteriores, impidiendo la lectura de usuarios o contraseñas.

- **Validación Práctica del Estudiante:**

Se abrieron `resultados/telnet.pcap` y `resultados/ssh.pcap` en Wireshark, confirmando en pantalla el usuario `secretaria` y la contraseña `Circular2026` en TELNET, mientras que la captura de SSH solo mostró entropía criptográfica ininteligible.

Sesión 2: Riesgo de Claves de Host Clonadas y Ataques de Intermediario (MitM)

- **Prompt enviado a la IA:**

> *"En la plantilla de la máquina virtual o contenedor, la clave de host de SSH tenía como comentario `root@buildkitsandbox`. ¿Cuál es el riesgo de seguridad real si varios servidores o estudiantes usan esa misma clave privada de host en producción?"*

- **Respuesta y Síntesis de la IA:**

La IA alertó que la clave privada de host autentica la identidad criptográfica del servidor ante los clientes. Si la clave privada de host es compartida por múltiples instancias, cualquier administrador o atacante que posea una copia puede levantar un servidor malicioso en la misma red y ejecutar un ataque de intermediario (*Man-in-the-Middle*). El cliente se conectará sin recibir ninguna advertencia de host cambiado (`known_hosts`), permitiendo al atacante interceptar o descifrar la sesión.

- **Acción y Validación:**

Se completó el TODO 1 en `preparar_ssh.sh` purgando las claves (`rm -f /etc/ssh/ssh_host_*`) y regenerándolas con `ssh-keygen -A`, obteniendo una huella única para `root@srv-horizonte`.

Sesión 3: Regla Estricta de OpenSSH para Jaulas Chroot y Permisos

- **Prompt enviado a la IA:**

> *"Al intentar conectar al usuario `comunicacion` enjaulado con SFTP, OpenSSH cierra la sesión y el journal muestra: `fatal: bad ownership or modes for chroot directory /srv/horizonte`. ¿Por qué ocurre y cómo se soluciona sin romper los permisos de escritura del equipo web?"*

- **Respuesta y Síntesis de la IA:**

La IA explicó la regla estricta de seguridad de OpenSSH: la carpeta especificada en `ChrootDirectory` y toda su ruta ascendente deben ser propiedad estricta de `root:root` y no tener permisos de escritura para grupo ni otros (`chmod 755`). Si `/srv/horizonte` tuviera permisos `775` o perteneciera al grupo `webadmin`, OpenSSH aborta inmediatamente la conexión para impedir que un usuario enjaulado modifique la raíz de su jaula o escale privilegios. La solución consiste en fijar `chown root:root /srv/horizonte` y `chmod 755 /srv/horizonte`, delegando la escritura a un subdirectorio interno `/srv/horizonte/www` con grupo `webadmin` y bit `setgid` (`chmod 2775`).

- **Acción y Validación:**

Se corrigió `endurecer_ssh.sh` con `chown root:root /srv/horizonte && chmod 755 /srv/horizonte`. Tras ello, la jaula SFTP funcionó a la perfección y el verificador pasó con éxito.

Sesión 4: Integración de Fail2ban con Systemd Journal y Nftables en Ubuntu 24.04

- **Prompt enviado a la IA:**

> *"En Ubuntu 24.04, Fail2ban reporta errores buscando `/var/log/auth.log` y el servicio ssh se llama `ssh.service`. ¿Cómo se configura correctamente el jail de SSH para que lea directo de systemd y bloquee usando nftables?"*

- **Respuesta y Síntesis de la IA:**

La IA indicó que Ubuntu 24.04 ya no instala rsyslog por defecto. Por ende, en `/etc/fail2ban/jail.d/horizonte-ssh.local` se debe especificar `backend = systemd` y definir el patrón de registro:

`journalmatch = _SYSTEMD_UNIT=ssh.service + _COMM=sshd`.

Asimismo, para la acción de baneo en distribuciones modernas, Fail2ban debe utilizar la acción de `nftables` (inyectando IPs en la tabla `inet f2b-table`).

- **Acción y Validación:**

Se aplicó la configuración, se reinició fail2ban y se ejecutó `fail2ban-client status sshd`, confirmando que el jail quedó activo leyendo de `_SYSTEMD_UNIT=ssh.service + _COMM=sshd` y descartando paquetes en `nftables`.

Sesión 5: Túneles SSH Locales vs Exposición Pública de Microservicios

- **Prompt enviado a la IA:**

> *"Tenemos un microservicio HTTP interno en `127.0.0.1:8081`. ¿Cuál es la sintaxis exacta para mapearlo a mi máquina local en el puerto 9081 mediante SSH sin abrir una terminal remota, y qué ventajas de seguridad ofrece frente a cambiar el puerto a `0.0.0.0:8081` en el firewall?"*

- **Respuesta y Síntesis de la IA:**

La IA explicó la sintaxis:

`ssh -N -L 9081:127.0.0.1:8081 horizonte`

Donde `-N` instruye a SSH a no ejecutar comandos remotos (solo reenviar puertos) y `-L` realiza el reenvío local. Detalló que exponer el puerto directamente en `0.0.0.0` permite a cualquier atacante en la red escanear y atacar el servicio directamente. Con el túnel SSH, el servicio permanece invisible en la red externa y todo el tráfico viaja protegido por el cifrado fuerte de OpenSSH.

- **Acción y Validación:**

Se levantó el túnel en segundo plano y se ejecutó `curl -s http://127.0.0.1:9081/eco`, obteniendo exitosamente el JSON estructurado de la API interna.

---

3. Matriz de Evaluación Crítica de Sugerencias de la IA

Consulta / Caso Técnico	Sugerencia Inicial de la IA	Decisión y Validación del Equipo	Riesgo Evitado
---	---	---	---
Comentarios en `sshd_config`	Añadir `# comentario descriptivo` al final de la directiva `ForceCommand internal-sftp`.	**Descartada:** Se colocó el comentario en una línea previa. OpenSSH no admite comentarios en la misma línea en `ForceCommand`.	Caída del daemon SSH y denegación de servicio a todos los usuarios de SFTP.

Consulta / Caso Técnico	Sugerencia Inicial de la IA	Decisión y Validación del Equipo	Riesgo Evitado
Nombre de la unidad SSH	Configurar `journalmatch = _SYSTEMD_UNIT=sshd.service`.	**Corregida:** En Ubuntu 24.04 la unidad de systemd es `ssh.service` (sin la 'd' final).	Fail2ban no habría leído ningún log, dejando el servidor desprotegido ante fuerza bruta.
Permisos de Chroot	Proponer `chmod 775 /srv/horizonte` para que el grupo `webadmin` pudiera escribir directamente en la raíz.	**Descartada enfáticamente:** OpenSSH prohíbe que el grupo tenga permisos de escritura en la raíz de la jaula. Se mantuvo `root:root (755)` en `/srv/horizonte` y se delegó escritura a `/srv/horizonte/www`.	Bloqueo total del inicio de sesión SFTP con error `bad ownership or modes for chroot directory`.
Regla de Oro ante Cambios	Reiniciar directamente el servicio `systemctl restart ssh` tras modificar la configuración.	**Complementada con protocolo estricto:** Primero validar sintaxis con `sshd -t` y mantener una segunda sesión SSH abierta como rescate antes de reiniciar.	Bloqueo administrativo remoto accidental por error de sintaxis en `10-horizonte.conf`.

---

4. Comprobación Oficial Automatizada del Entorno

Laboratorio 10 (11 de 11 Comprobaciones Aprobadas)

```
root@srv-horizonte:~/lab10# bash verificar_lab10.sh estudiante
☑ Captura TELNET: la contraseña se lee en claro
☑ Captura SSH: contraseña y datos NO se leen
☑ Claves de host propias (no las de la imagen)
☑ known_hosts con la huella real del servidor
☑ Clave del cliente ed25519
☑ Clave pública autorizada en la cuenta de estudiante
☑ Permisos de ~/.ssh (700) y authorized_keys (600)
☑ Acceso con clave y alias 'horizonte' (sin contraseña)
☑ Intercambio de claves híbrido post-cuántico
☑ comunicado.html publicado por scp (dueño estudiante, grupo webadmin)
☑ TELNET desactivado al terminar (puerto 23 cerrado)
Resultado: 11 de 11 comprobaciones
```

Laboratorio 11 (15 de 15 Comprobaciones Aprobadas)

```
root@srv-horizonte:~/lab11# bash verificar_lab11.sh estudiante
☑ sshd -t sin errores
☑ root no puede entrar por SSH
☑ Contraseñas desactivadas (solo claves)
☑ estudiante entra con su clave (alias horizonte)
☑ Solo los grupos sshadmins y sftp-web (y estudiante en sshadmins)
☑ comunicacion publica por SFTP (archivo 664, grupo webadmin)
☑ comunicacion está enjaulado (no ve /etc)
☑ comunicacion no obtiene terminal (solo SFTP)
☑ Intercambio de claves post-cuántico primero
☑ El registro guarda la huella de la clave usada
☑ Aviso legal en ASCII (/etc/issue.net)
☑ fail2ban activo
☑ fail2ban lee el journal de ssh.service
☑ fail2ban bloquea en nftables
☑ Túnel local: API interna 8081 alcanzable por SSH
Resultado: 15 de 15 comprobaciones
```